

Volume 13 – Security Architecture & Compliance

AI Quant Trading Platform

Version: 1.0

Document Type: Security Architecture & Compliance

Classification: Enterprise Security

1. Purpose

This document defines the complete security architecture for the AI Quant Trading Platform.

The objective is to protect:

- User Accounts
- Exchange API Keys
- Trading Data
- AI Models
- Financial Information
- Platform Infrastructure

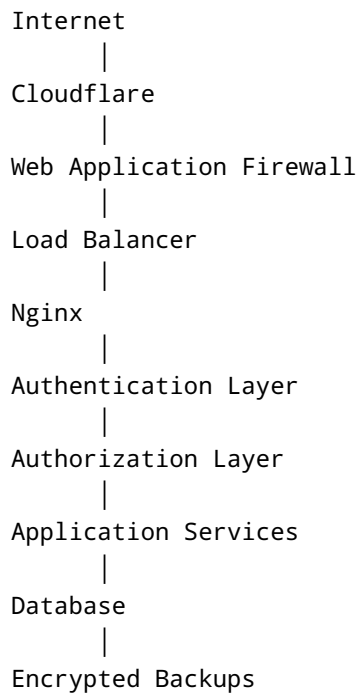
Security shall be implemented using a defense-in-depth approach where multiple independent controls reduce overall risk.

2. Security Principles

The platform follows these principles:

- Zero Trust Architecture
 - Least Privilege Access
 - Defense in Depth
 - Secure by Default
 - Privacy by Design
 - Encryption Everywhere
 - Continuous Monitoring
 - Complete Auditability
-

3. Security Architecture



Every layer performs independent validation.

4. Identity Management

Supported Authentication

- Email + Password
- OAuth Providers (Future)
- Two-Factor Authentication (TOTP)
- Recovery Codes

Future Support

- Passkeys
 - Hardware Security Keys (FIDO2/WebAuthn)
-

5. Password Policy

Requirements

- Minimum Length
- Password Hashing (Argon2 or bcrypt)
- Password History

- Password Reset Tokens
- Account Lockout
- Login Rate Limiting

Passwords are never stored in plaintext.

6. Session Security

Requirements

- JWT Access Tokens
 - Refresh Tokens
 - Session Expiration
 - Device Tracking
 - Manual Session Revocation
 - Forced Logout
-

7. Authorization

Role-Based Access Control (RBAC)

Roles

- Guest
- User
- Premium
- Enterprise
- Support
- Admin
- Super Admin

Permissions are assigned to roles, not directly to users.

8. Multi-Tenant Isolation

Each tenant is isolated through:

- Tenant Identifier
- Row-Level Authorization
- API Validation
- Audit Logging

No tenant can access another tenant's data.

9. Exchange API Key Security

Requirements

- Encrypt credentials at rest
- Never display full secrets
- Rotate credentials when required
- Validate permissions before use
- Log key usage events

Exchange secrets are decrypted only when required for communication.

10. Encryption

Data in Transit

- TLS 1.3 (or current secure equivalent)

Data at Rest

- AES-256 encryption for sensitive fields

Backups

- Encrypted before storage
-

11. API Security

Controls

- HTTPS Only
 - JWT Authentication
 - API Rate Limiting
 - Request Validation
 - Response Sanitization
 - Idempotency for order creation
 - Input Validation
-

12. Secure Coding

Developers shall follow:

- OWASP Top 10 guidance
- Parameterized database queries

- Output encoding
 - Secure dependency management
 - Principle of least privilege
-

13. Input Validation

Validate

- Length
- Type
- Format
- Range
- Enum Values
- File Uploads

Reject invalid requests before business logic.

14. Audit Logging

Log

- Login
- Logout
- Password Changes
- API Key Updates
- Exchange Connections
- Strategy Changes
- Order Placement
- Order Cancellation
- Admin Actions

Audit logs are immutable and timestamped.

15. Threat Protection

Protection Against

- SQL Injection
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- SSRF
- Command Injection
- Path Traversal
- Clickjacking
- Session Hijacking

16. Rate Limiting

Limits apply to:

- Login
- API Requests
- Password Reset
- Registration
- Order Submission

Rate limits are configurable by subscription tier.

17. Infrastructure Security

Servers

- SSH Keys
- Firewall
- Automatic Security Updates
- Fail2Ban

Containers

- Non-root Execution
 - Resource Limits
 - Vulnerability Scanning
-

18. Monitoring & Detection

Monitor

- Failed Logins
- Suspicious API Usage
- Privilege Escalation
- High Error Rates
- Exchange Authentication Failures
- Unusual Trading Activity

Alerts are sent to administrators for review.

19. Incident Response

Process

Detection



Investigation



Containment



Recovery



Root Cause Analysis



Documentation

Every security incident receives a unique incident ID.

20. Compliance Considerations

Design the platform to support future compliance requirements such as:

- Data retention policies
- User data export
- User data deletion
- Audit reporting

Applicable legal and regulatory requirements will depend on the deployment jurisdiction.

21. Backup Security

Backups

- Encrypted
 - Integrity Checked
 - Access Controlled
 - Periodically Tested
-

22. Business Continuity

Requirements

- Redundant Infrastructure
 - Backup Verification
 - Disaster Recovery Procedures
 - Recovery Testing
 - Service Health Monitoring
-

23. Security Testing

Perform

- Static Analysis
- Dependency Scanning
- Penetration Testing
- API Security Testing
- Authentication Testing
- Authorization Testing

Findings must be tracked until resolved.

24. Logging Policy

Every security event records:

- Timestamp
- User
- Tenant
- IP Address
- Action
- Result
- Correlation ID

Sensitive values must never appear in logs.

25. AI Security

Protect

- Model Files
- Feature Store
- Training Data

- Model Registry
- Inference API

Model deployment requires authorization and version tracking.

26. Future Security Enhancements

- Hardware Security Modules (HSM)
 - Secrets Management Platform
 - Passkeys
 - WebAuthn
 - Continuous Threat Detection
 - Behavioral Authentication
 - Risk-Based Authentication
 - Security Information and Event Management (SIEM)
-

27. Security Principles

- Every request is authenticated.
- Every action is authorized.
- Sensitive information is encrypted.
- Auditability is mandatory.
- Fail securely by default.
- Security controls must not be bypassed by AI modules or automation.
- Regular reviews and testing are required to maintain the security posture.